

# Screened at the door, ruled by a human, receipted on the way out

Opt-in per deployment (UNDERCROFT\_ADMISSION=quarantine) — off, the write contract is byte-identical. On, this is the path every save takes.

## A save arrives

MCP tool · REST /v1 · CLI · bulk ingest — the handler stamps added\_by: a writer cannot choose its surface. Updates are re-stamped with the surface writing NOW — never the original writer's standing.

Provenance claims (agent / channel / session) travel HMAC-covered — **evidence, never a boundary.**

## Trusted surface? Straight in.

UNDERCROFT\_ADMIT\_TRUSTED\_SOURCES matches the stamped added\_by only — a claim cannot admit itself. The bypass is the deployment's own declaration.

## Tier 1 — deterministic. No model, no network; signal codes and byte offsets, never content.

A closed vocabulary, so the review queue reads as data. One signal per class, offsets into the candidate; independent classes record independent evidence.

imperative-instruction

tool-call-syntax

exfil-marker

encoded-blob

### fixture-similarity

Windowed hash-embedder cosine against 18 committed attack fixtures — catches the variant that dodges every marker substring. Threshold pinned from both sides; measured 0/5,882 clean-corpus **false positives**, 18/18 fixtures trip their own screen.

### rate-anomaly

The signal candidate bytes cannot carry: a declared per-writer budget (UNDERCROFT\_ADMISSION\_RATE=count/seconds), read from the vault's own history. Identity = agent claim, else the stamped surface among claim-less rows. Declared, never defaulted.

no signal

## Tier 2 — a local model's opinion, advisory-only (UNDERCROFT\_ADMISSION\_LLM=advisory)

Consulted only for tier-1-clean candidates, only toward quarantine — flagged content is never shown to it, so talking the classifier into "clean" bypasses nothing. A failed answer is a non-event, never a blocked write. The model is itself an injection target, steerable only in the safe direction.

any signal → diverted, never rejected, never silently dropped

## Clean — lands where it aimed

Sealed, HMAC-tagged, chain-appended in the same transaction — the ordinary write path, untouched.

## The quarantine wing — reserved, sealed, and outside every answer

The drawer keeps its verbatim content, sealed like any other; signal codes, offsets and the intended destination ride in metadata. Hard-excluded from retrieval except a reviewer's explicitly named scope — it can neither answer nor crowd. The wing refuses forged residents (a caller cannot aim a save here), quarantined drawers are not editable (the reviewer rules on exactly what the screen saw), and a flagged UPDATE diverts while the original drawer keeps its previous content.

## allow — re-filed where it was headed

The human ruling IS the override: the content still trips the screen, so the re-file goes straight to the write path, never back through it.

## deny — destroyed, with a receipt

Rides the attested-forgetting path (C3.2): heads before/after, the tombstone interval, content fingerprints — verifiable by third parties.

Every ruling is a chain record with the verdict inside its tag's canonical — the review trail is as tamper-evident as the data. Detection is heuristic and says so: markerless poison passes, prose about injection can trip — which is exactly why a signal quarantines for a human and never rejects.